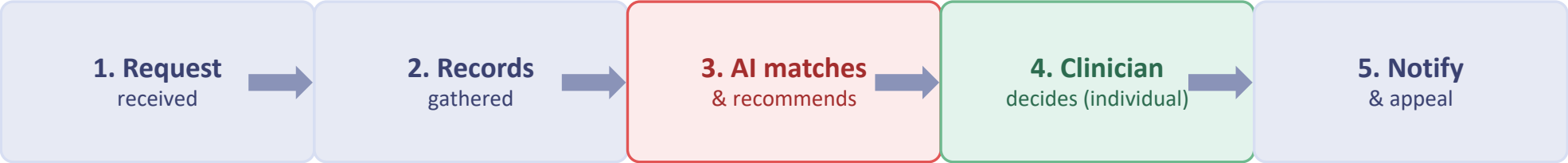


AI recommends — but a clinician must make the decision

AI optimizes criteria matching at step 3. That step carries the program's critical risk.



AI risks at step 3

Overrides clinician

Denies on prediction alone — violates the CMS individual-basis rule. (OWASP LLM06, LLM09)

Confabulated rationale

Plausible-sounding medical-necessity reason that is simply wrong. (OWASP LLM09)

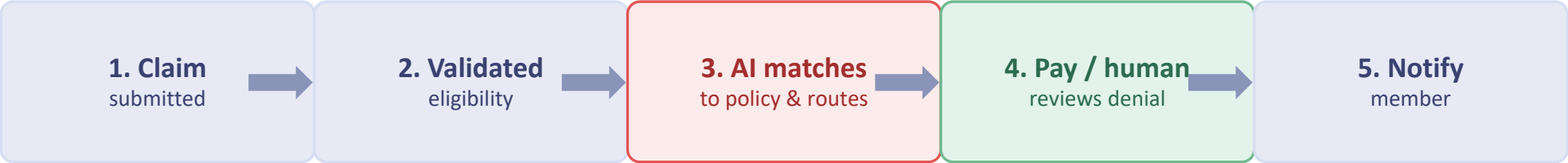
Bias at scale

Systematic disadvantage to protected groups across all requests. (NIST Harmful Bias)

Control AI is decision-support only — it never denies. A licensed clinician makes every adverse determination; each denial is logged and appealable.

AI can auto-approve claims — but never auto-deny

AI optimizes claim-to-policy matching at step 3. The denial path is where the legal exposure sits.



AI risks at step 3

Batch denial

Mass auto-denials without individual review — the Cigna Px Dx pattern. (OWASP LLM06)

Wrong interpretation

Misreads policy language and denies a covered claim. (OWASP LLM09, LLM05)

Non-explainable

Denial with no defensible reason — ERISA / bad-faith exposure. (Info Integrity)

Control Auto-approval is fine; every denial routes to a human with an explainable rationale. No batch adverse actions; inputs and outputs logged.

AI flags suspicious claims — a human investigator decides

AI optimizes anomaly detection across the claims stream at step 3. False positives hit real providers.



AI risks at step 3

False positives
Legitimate providers and members flagged and harmed. (OWASP LLM09, Harmful Bias)

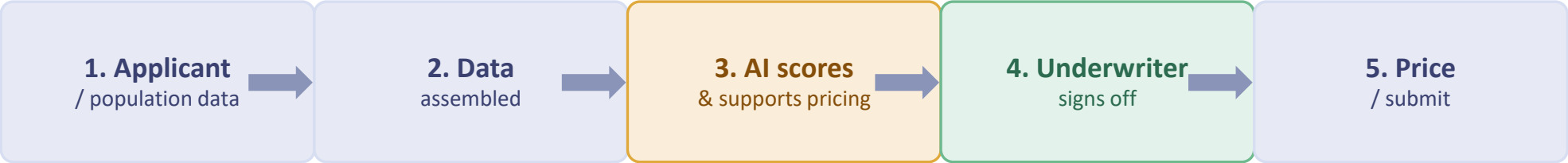
Adversarial evasion
Fraudsters poison or game inputs to slip past detection. (OWASP LLM04, LLM08)

Opaque flags
A flag that can't be explained or defended in an audit. (Information Integrity)

Control AI flags only — a human investigator confirms before any action against a provider. Explainable rationale, appeal path, drift monitoring.

AI scores risk — a human underwriter signs off

AI optimizes risk scoring and pricing at step 3. Discrimination and PHI exposure are the key risks.



AI risks at step 3

Proxy discrimination

Unfair pricing via proxies for protected class — NAIC bulletin focus. (NIST Harmful Bias)

RAF upcoding

Inflated risk-adjustment codes — False Claims Act exposure. (OWASP LLM09, LLM05)

PHI leakage

Member data exposed via model training or memorization. (OWASP LLM02)

Control Fairness + proxy testing before deploy; documented justification; human sign-off. PHI minimized; no-train / no-retain clauses; vendor BAA.